

Privacy Statement

Last updated: September 2026.

1. What We Collect

Category	Examples	Where it's stored
Account data	Name, email, password (hashed, never stored in plain text), organization, role	Postgres (persistent)
Clinical/ vitals data	ECG readings, heart rate, QTc, HRV, imaging metadata, care-continuum status	In-memory on the application server — not currently persisted to a database; lost on server restart unless this has since changed
Payer/ claims data	X12 837/834 claims and enrollment data, contracts, invoices	In-memory on the application server — same persistence caveat as above
Due-diligence documents	Files uploaded to the Data Room's Document Room	Cloudflare R2 if configured; otherwise local disk, which does not survive a redeploy
Session data	A signed session token identifying your account and role	An httpOnly browser cookie — not readable by JavaScript, not stored server-side beyond the

2. How We Use It

Account data is used to authenticate you and enforce role-based access. Clinical and payer data is used to run the risk-assessment pipeline and generate the reports, dashboards, and alerts the Service displays to authorized users within your organization. We do not sell data to third parties.

3. Who Can See What

Access is scoped by organization and role. A clinician-role account can reach clinical data through the Main Engine and Clinician Dashboard; a payer-analyst account can reach payer data through the Payer Portal; neither can reach the other's surface. Admins and super admins within an organization can see all data belonging to that organization. Data Room access uses a separate, single shared access code independent of organizational accounts, since due-diligence reviewers are typically not members of the company's own organization.

4. Data Retention and the Persistence Gap, Stated Directly

Some categories of data in this system are not yet backed by persistent storage — specifically clinical/vitals data and payer/claims data, which currently live only in the running application process's memory. This means that data does not currently survive a server restart or redeployment. Document Room uploads persist only if Cloudflare R2 has been configured; otherwise they are also lost on redeploy. This is disclosed here because it directly affects what "we retain your data" can honestly mean in the current state of this system — not a purely theoretical caveat.

5. Third-Party Infrastructure

This Service runs on Render (application hosting and managed Postgres) and, optionally, Cloudflare R2 (document storage). Neither has a signed Business Associate Agreement with us as of this document's last update — see the BAA document for what this means if real protected health information is involved.

6. Security Measures

Passwords are hashed with bcrypt, never stored in plaintext. Session tokens are signed (JWT) and delivered via httpOnly cookies. Role-based access control is enforced server-side on every request, not just hidden in the interface. Data Room access uses a separate, independently-checked access code.

7. Your Rights

You may request access to, correction of, or deletion of your account data by contacting your organization's admin or super admin, who can view and manage accounts within your organization, or by contacting us directly.

8. Contact

Questions about this Privacy Statement: invest@cardioalive.com